Informe Oficial de Auditoría Forense y Dictamen de Incidentes

Análisis Exhaustivo del Dataset SIEM Multi-Incidente (Comunidad DOJO Challenge)

Dataset Analizado:	SOC_L2_Logs_Ampliados_Multiples_Incidentes.xlsx	Total Registros:	715 eventos auditados
Hash SHA-256 (Custodia):	0e5d5de56da596bf6b279a07f51e29498ad86782256cd842f42328543708a0c9	Ventana Temporal:	2026-10-23 (07:46:07 — 13:44:06)
Alcance Infraestructura:	11 Hosts (DC-01, FS-SRV01, DB-SRV01, WEB-01, APP-SRV01, Estaciones)	Estándar Metodológico:	NIST SP 800-61 Rev 2 + MITRE ATT&CK; v14

1. Resumen Ejecutivo (Dictamen para la Dirección y Gerencia)

Durante la auditoría forense digital realizada sobre los registros consolidados del SIEM correspondientes a la jornada del 23 de octubre de 2026, el motor analítico de SentinelAI SOC L2 procesó la totalidad de los 715 eventos. Si bien el 82.8% (592 eventos) representa actividad operacional y administrativa ordinaria, se confirmaron 6 incidentes de seguridad coordinados de gravedad crítica y alta, totalizando 123 eventos maliciosos y anómalos.

Impacto en la Organización: Se identificó la sustracción exitosa de información financiera confidencial (Budget2027.xlsx) y expedientes legales completos (archive.7z con 241.57 MB transferidos en 22 sesiones HTTPS salientes hacia infraestructura externa). Adicionalmente, se detectó una fase preparatoria de ransomware consistente en la eliminación de copias sombra de volumen (VSS) y la instalación de mecanismos de persistencia furtiva mediante servicios del sistema y tareas programadas.

CRITICIDAD ALTA / CRÍTICA	RIESGO MEDIO (SOSPECHOSO)	ACTIVIDAD OPERACIONAL	INCIDENTES MULTI-ETAPA
41 eventos (5.7%)	82 eventos (11.5%)	592 eventos (82.8%)	6 Confirmados
Exfiltración, RCE, Borrado VSS	Password Spray, Fuerza Bruta RDP	Logons rutinarios, tráfico interno	Cadena de ataque mapeada

2. Catálogo Forense de Incidentes Identificados (Triage SOC Nivel 2)

A continuación se detalla la matriz de correlación de los 6 incidentes detectados en el dataset, indicando su vector de entrada, observables clave (IoCs), coordenadas físicas en el archivo de registro (S1-Rxx) y técnicas MITRE ATT&CK; asociadas:

ID	Incidente y Vector	Riesgo	Hosts / Identidades	MITRE ATT&CK;	Evidencias y Celdas Excel
INC-01	Password Spraying Externo Sondeo automatizado cada 19s hacia DC-01 con éxito posterior.	ALTO	DC-01, WS-031 CORP\mgarcia	T1110.003 T1078.002	33 fallos 4625 (S1-R57..111) seguidos de logon 4624 (S1-R124) y privilegios 4672.
INC-02	Intrusión RDP y Exfil Financiera Movimiento lateral SMB y empaquetado de presupuesto 2027.	ALTO	APP-SRV01, FS-SRV01 CORP\admin	T1021.001 T1560.001 T1041	Fuerza bruta 3389 desde 198.51.100.77, tar.exe -cf finance.zip y exfil a 203.0.113.88:443.
INC-03	Pre-Ransomware: Borrado VSS Secuestro de cuenta de servicio y harvesting financiero secuencial.	CRÍTICO	WS-023, FS-SRV01 CORP\backupsvc	T1490 T1059.001 T1039	Extracción de 16 documentos FY2026 y ejecución de vssadmin delete shadows /all /quiet (S1-R245).
INC-04	Exfiltración Masiva Legal (HTTPS) Compresión 7z de expedientes y fuga de alto volumen por Proxy.	CRÍTICO	WS-018, Proxy CORP\rrojas	T1560.001 T1048	7z.exe archive.7z C:\Legal*.docx + 22 sesiones HTTPS POST (241.57 MB) a 198.51.100.88:443.
INC-05	Persistencia: Servicio y Tarea Instalación de binario sospechoso y beaconing recurrente.	ALTO	APP-SRV01 CORP\helpdesk	T1543.003 T1053.005	Servicio WinUpdateHelper (7045) y tarea UpdateCheck (4698) con wuhelper.exe.
INC-06	Ataque Web IIS y Webshell RCE Explotación en servidor web y ejecución remota bajo DefaultAppPool.	ALTO	WEB-01 DefaultAppPool	T1190 T1505.003 T1059.003	Petición a /uploads/test.aspx?cmd=whoami (S1-R590) originando proceso cmd.exe desde 192.0.2.91.

3. Ingeniería de Detección (Detection-as-Code) y Cadenas de Ataque

Para garantizar la reproducibilidad técnica en entornos SIEM de producción (Microsoft Sentinel, Splunk y Wazuh), se han formalizado las reglas analíticas de detección correspondientes a los patrones descubiertos:

Regla KQL (Microsoft Sentinel) — Detección INC-01 (Password Spraying Correlacionado)

```
SecurityEvent
| where EventID == 4625 and IpAddress == '203.0.113.74'
| summarize IntentosFallidos = count(), CuentasAtacadas = make_set(TargetUserName) by bin(TimeGenerated, 5m), IpAddress, Computer
| where IntentosFallidos >= 10
| join kind=inner (
    SecurityEvent | where EventID in (4624, 4672) and IpAddress == '203.0.113.74'
    | project TiempoCompromiso = TimeGenerated, UsuarioComprometido = TargetUserName, Computer, IpAddress
) on IpAddress
```

Regla Sigma (YAML Estandarizado) — Detección INC-03 (Pre-Ransomware VSS Deletion)

```
title: Shadow Copies Deletion via VSSAdmin Pre-Ransomware
status: production | logsource: { product: windows, category: process_creation }
detection:
  selection:
    Image|endswith: '\vssadmin.exe'
    CommandLine|contains|all: [ 'delete', 'shadows' ]
  condition: selection | level: critical | tags: [ attack.impact, attack.t1490 ]
```

Fundamentación del Motor de Detección de Anomalías Multivariable

A diferencia de soluciones basadas en listas estáticas de cadenas de texto, SentinelAI SOC L2 evalúa cada fila del dataset mediante una función multivariable continua de anomalía ($0.00 \le \text{Score} \le 1.00$):

Score Compuesto = 0.35 · R_net + 0.30 · A_cmd + 0.20 · S_rarity + 0.15 · W_sev

• R_net (Riesgo de Red): Pondera el cruce de fronteras de red entre direcciones privadas RFC 1918 e IPs públicas no corporativas.
• A_cmd (Anomalía de Comando): Desviación Z-score de longitud respecto a la media poblacional sumada a heurísticas de evasión (Base64, EncodedCommand, vssadmin, 7z).
• S_rarity (Information Surprisal): Puntuación logarítmica $-\log_2(p)$ sobre la frecuencia de ocurrencia del par Log_Source::Event_ID.
• W_sev: Ponderación del campo original de severidad del SIEM.

4. Plan de Contención SOAR, Recomendaciones y Cadena de Custodia

Conforme al marco de respuesta a incidentes NIST SP 800-61 Rev 2, se emitieron los siguientes procedimientos de contención técnica inmediata listos para ejecución mediante PowerShell en Active Directory y Firewall corporativo:

Script DFIR de Contención Inmediata (PowerShell Automatizado)

```
# 1. Bloqueo en Firewall Perimetral de los 5 IoCs Externos Auditados
New-NetFirewallRule -DisplayName 'SOC-BLOCK-ATTACKERS' -Direction Inbound -Action Block `
    -RemoteAddress '203.0.113.74', '198.51.100.77', '198.51.100.88', '203.0.113.88', '192.0.2.91'
# 2. Deshabilitar Cuentas Comprometidas y Revocar Tokens de Acceso
Disable-ADAccount -Identity 'mgarcia'; Disable-ADAccount -Identity 'rrojas'; Disable-ADAccount -Identity 'backupsvc'
Revoke-AzureADUserAllRefreshToken -ObjectId 'mgarcia@corp.local' -ErrorAction SilentlyContinue
# 3. Erradicación de Persistencia en Servidor APP-SRV01
Stop-Service -Name 'WinUpdateHelper' -Force; sc.exe delete 'WinUpdateHelper'
Unregister-ScheduledTask -TaskName '\Microsoft\Windows\UpdateCheck' -Confirm:$false
Remove-Item -Path 'C:\ProgramData\wuhelper.exe' -Force
# 4. Contención de Webshell y Application Pool en WEB-01
Stop-WebAppPool -Name 'DefaultAppPool'; Remove-Item 'C:\inetpub\wwwroot\uploads\test.aspx' -Force; iisreset /restart
```

Recomendaciones de Seguridad y Hardening

1. Segmentación de Red y Bloqueo RDP Directo: Restringir el puerto 3389 exclusivamente a través de túneles VPN autenticados con MFA y gateways de acceso seguro (Bastion).
2. Implementación de LAPS y Cuentas de Servicio Administradas (gMSA): Reemplazar cuentas estáticas como CORP\backupsvc por gMSA con rotación automática de credenciales para evitar abusos de tokens.
3. Restricción de Directorios de Carga en IIS: Deshabilitar permisos de ejecución de scripts (.aspx, .php) en carpetas de uploads públicos mediante reglas de web.config.
4. Protección de VSS y Respaldos Inmutables: Aplicar políticas de auditoría estricta sobre invocaciones a vssadmin.exe y configurar copias de seguridad desconectadas (Air-Gapped).

CERTIFICACIÓN FORENSE Y CADENA DE CUSTODIA	ACCESO AL CÓDIGO Y EVIDENCIA
Analista Certificador: SOC L2 Forensic Analyst Organización Evaluadora: Fundación Comunidad DOJO Hash del Informe: SHA-256 Verificado e Inmutable Integridad del Dataset: Coincide 100% con fuente original	Repositorio Oficial en GitHub: https://github.com/acuptor01a/sentinelai-soc-l2 Publicación en Vivo: https://acuptor01a.github.io/sentinelai-soc-l2/